

한국승강기안전공단 상임감사

개 선 요 구

제 목 업무수행 주체가 불분명한 내규 개선

소 관 부 서 ◇팀

조 치 부 서 ◇팀

내 용

1. 업무 개요

가. 정보화 사업 추진에 대한 보안성 검토 업무

○실은 차 년도 정보화 사업에 대한 수요조사를 실시하고 확정된 정보화 사업은 사업을 추진하고자 하는 담당부서에서 내부계획 보고 후 계약부서에 계약의뢰 하고 있다.

계약부서에 계약의뢰 전 담당부서는 ◇팀에 정보화사업에 대한 보안성 검토를 의뢰 하고 ◇팀은 필요시 국가정보원장 또는 행정안전부장관(이하 “국가정보원장 등” 이하 함)에게 보안성 검토를 요청하고 있으며 보안성 검토결과를 통보받은 경우 담당부서 에서 검토결과를 반영하여 보안대책을 보완하고 있다.

나. 정보시스템 접속기록 유지·관리 및 점검 업무

공단은 정보시스템의 효율적인 통제·관리 및 사고 발생 시 추적 등을 위하여

접속자, 자료의 열람·출력 등 작업 종류 및 시간 등의 접속기록을 유지·관리하고 있다.

◇팀에서는 연 2회(상반기, 하반기) 공단의 전체 서버와 보안장비를 대상으로 접속기록을 점검하여 비인가자의 접속 시도, 비정상 행위, 권한 외 접근에 대한 이상 유무를 확인하고 있다.

2. 관련 내규 및 판단기준

가. 정보화 사업 추진에 대한 보안성 검토 업무

공단 내규인 「정보보안관리규칙」 제15조를 보면 분임정보보안담당관(부서 및 지역 사무소의 장)이 정보화사업을 수행하고자 할 경우 보안대책의 적절성을 평가하기 위하여 사업공고 전 보안성 검토를 ◇팀에 의뢰하도록 하고 있고, 같은 규칙 제16조제1항 및 제2항에 해당하는 정보화사업은 각각 국가정보원장, 행정안전부장관(이하 ‘국가정보원장 등’ 이라 함)에게 보안성 검토를 요청하도록 하고 있다.

또한, 같은 규칙 19조를 보면 같은 규칙 제16조에 따라 요청한 보안성 검토에 대한 결과를 국가정보원장 등에게 통보받은 경우, 정보보안책임관(△처장)이 검토결과를 반영하여 보안대책을 보완하도록 하고 있다.

따라서, 정보보안책임관(△처장)은 국가정보원장 등에게 보안성 검토결과를 통보받은 경우 검토결과를 반영하여 보완하여야 한다.

나. 정보시스템 접속기록 유지·관리 및 점검 업무

공단 내규인 「정보보안관리규칙」 제46조제1항을 보면 정보보안담당관(◇팀

장)은 정보시스템의 효율적인 통제·관리 및 사고 발생 시 추적 등을 위하여 접속기록을 유지·관리하도록 하고 있다.

또한, 같은 조 제4항에서는 정보시스템 관리자(○실)는 접속기록을 정기적으로 점검하고 비(非)인가자의 접속 시도, 자료의 위·변조 및 삭제 등 의심스러운 정황이나 위반한 사실을 발견할 시에는 즉시 정보보안담당관(◇팀장)에게 통보하도록 하고 있다.

따라서, 정보보안담당관(◇팀장)은 정보시스템의 접속기록을 유지·관리하여야 하며, 정보시스템 관리자(○실)는 접속기록을 정기적으로 점검하여 비(非)인가자의 접속 시도 등이 발견되면 정보보안담당관(◇팀장)에게 통보하여야 한다.

3. 감사결과 확인된 문제점

가. 정보화 사업 추진에 대한 보안성 검토 업무

정보보안책임관(△처장)은 「정보보안관리규칙」 제19조에 따라 국가정보원장 등으로부터 보안성 검토결과를 통보받은 경우 이를 반영하여 보안대책을 보완하도록 하고 있다.

그러나, 실제 업무상 국가정보원장 등이 통보한 보안성 검토결과의 보안대책을 마련하는 주체는 정보화 사업을 추진하는 분임정보보안담당관(부서 및 지역사무소의 장)이 하고 있고, 상위 지침인 행정안전부 「정보보안지침」 제20조에서도 보안성 검토결과를 반영하여 보안대책을 마련하는 업무수행 주체는 분임정보보안담당관으로 규정하고 있음에

따라 실제 업무수행 주체에 맞게 내규를 개정할 필요가 있다.

나. 정보시스템 접속기록 유지·관리 및 점검 업무

공단 내규인 「정보보안관리규칙」 제46조 제1항에서는 정보시스템의 접속기록을 유지·관리하는 업무수행 주체를 정보보안담당관(◇팀장)으로 하고 있으며, 정보시스템의 접속기록을 정기적으로 점검하는 업무수행 주체를 정보시스템 관리자(○실)로 규정하고 있다.

그러나 실제 업무상 정보보안담당관(◇팀장)은 정보시스템 접속기록의 유지·관리를 위한 시스템의 접근권한은 갖고 있지 않으며, 정기적으로 실시하는 정보시스템 접속기록에 대한 점검은 ◇팀에서 수행하고 있어 「정보보안관리규칙」에서 규정하고 있는 업무수행 주체와 다르게 운영하고 있다.

따라서 「정보보안관리규칙」에서 규정하고 있는 정보시스템 접속기록의 유지·관리와 정보시스템 접속기록 점검에 대한 업무수행 주체에 맞게 규칙을 개정할 필요가 있다.

관계부서 의견 ◇팀은 「정보보안관리규칙」상 사업수행 주체가 실제와 다른 부분을 인정하였으며 규칙을 개정하겠다는 의견을 제시하였다.

조치할 사항 ◇팀장은 정보화 사업 추진의 보안성 검토결과 보완과 정보시스

템 접속기록 유지·관리 및 점검에 대한 업무가 실제 업무수행 주체와 일치되도록 「정보보안관리규칙」을 개정하시기 바랍니다.(개선)